DarkZeroReturns

授權滲透測試與攻擊路徑 SOP

目標：10.129.156.169
發現網域：dzcampaigns.htb / darkzero.ext
測試日期：2026 年 10 月 31 日至 11 月 1 日

執行狀態：部分完成
已驗證 Web 遠端命令執行、讀取應用主機資料、取得網域帳號的 Kerberos 身分並建立 Gitea 測試 PR。user.txt 與 root.txt 尚未讀取；後續 CI 執行遭 Gitea 的 fork 工作批准條件阻擋，fork 工作亦停留在 queued。報告不以外部解題資料替代旗標佐證。

機密處理：此報告遮蔽密碼、雜湊、session secret 與旗標內容。測試中建立了隔離的測試帳號、fork、branch 與 PR；未合併 upstream PR。

1. 摘要與範圍

本次為使用者明確授權的 Hack The Box 靶機測試。對外目標為 10.129.156.169；測試沿著 Web 應用、資料庫設定、Kerberos 與 Gitea Actions 展開。應用程式存在高風險的任意程式碼執行：使用者可透過 JSON 物件型別繞過字串驗證，讓 Handlebars 4.7.8 編譯攻擊者控制的 AST。實際回呼已證明以 darkzero 服務帳號執行命令。

項目	結果
主要入口	HTTP 80 → dzcampaigns.htb；SSH 22
主機系統	SRV01，Ubuntu 24.04.4，Linux 6.8.0-136-generic
應用服務	Node.js / Express / Handlebars 4.7.8；Gitea 1.25.0 於內部 3000/tcp
已驗證最高權限	應用服務帳號 darkzero（UID 996）；未取得 root 或 DC 管理員權限
旗標	user.txt：未取得；root.txt：未取得；未提供推測值
掃描完整度	全 TCP 掃描因 host timeout 未完成；報告只將 22、80 列為已確認對外開放埠

風險排序

等級	發現	影響
Critical	CVE-2026-33940 型別混淆造成伺服器端程式碼執行	登入使用者可在 Web 服務帳號權限下執行命令；讀取本機設定與秘密
High	明文資料庫憑證存於應用 .env，資料庫保存身份驗證雜湊	設定檔外洩及服務帳號入侵可能導致憑證重用與內網橫向移動
Medium	Gitea Actions PR 工作流程可執行 repo 程式碼；runner 使用 svc-runner 身分	若 fork PR 被批准/執行，惡意 CI 可取得 runner 身分與可讀檔案

2. 範圍、規則與可重現環境

目標主機：10.129.156.169。應用虛擬主機：dzcampaigns.htb。內部域名：darkzero.ext；SRV01 內網位址 172.16.20.3，DC02 172.16.20.2。這些內部位址由已取得的 target-side name resolution 與連線測試觀察而來。沒有對非靶機網段做橫向掃描。

準備與 DNS 解析

```
sudo openvpn <HTB-VPN-profile>.ovpn
# ■■ VPN ■■■■■■■■■
ip addr show
ip route get 10.129.156.169
# ■■■■ Web ■■■■■■■■■■
echo "10.129.156.169 dzcampaigns.htb" | sudo tee -a /etc/hosts
```

服務探測（本次完成的證據）

```
nmap -Pn -n -sV -sC -p22,80 --reason -oA reports/10.129.156.169_tcp_services 10.129.156.169
# ■ TCP ■■■ --host-timeout ■■■■■■■■■■■■■■■ filtered/closed■
```

```
tu13.18

s confirmed.
```

結果：22/tcp OpenSSH 9.6p1；80/tcp nginx 1.24.0，導向 dzcampaigns.htb。全埠掃描必須在較長窗口重跑，確認是否另有外部服務。

3. Web 應用檢測 SOP

3.1 資產與驗證流程

先以瀏覽器或 curl 存檔首頁、登入、註冊、dashboard、campaign 頁與靜態 JavaScript；記錄 cookie、安全標頭與重導向。使用專用測試帳號，避免使用真實帳戶。以普通字串測試 campaign_message，再以 JSON 型別變化檢查伺服器端 validator。

```
curl -i http://dzcampaigns.htb/
curl -sS -D reports/headers.txt -o reports/home.html http://dzcampaigns.htb/
# ■■■■■■■■■■■■■■ dz.sid ■ CSRF token
# ■■■■■■■■ object ■■■ /character ■■
```

3.2 應用檔案與資料流定位

取得遠端命令執行後，以只讀方式定位程式碼：/opt/DarkZero_Campaigns/src/controllers、src/validators、src/services、src/models、package.json 與 package-lock.json。檢查 route → validator → service → DB model 的資料流。重點檔案為 character 路由/驗證器、MessageService 與 package-lock 中 Handlebars 版本。

檢測點	實際觀察	判斷
欄位驗證	campaign_message 僅限制長度，沒有 string 型別檢查	JSON object 可通過表面驗證
模板使用	MessageService 將自訂訊息交由 Handlebars.compile()	攻擊者控制資料被視為模板/AST輸入
依賴版本	package.json 與 lockfile 顯示 handlebars 4.7.8	落在 GHSA-xhpv-hc6g-r9c6 受影響範圍
XSS 對照	普通 HTML 內容被 HTML-escape	本次不報告 stored XSS

驗證器建議包含 isString 與長度上限；服務層仍須拒絕非字串，不能只依賴 controller 驗證。移除自訂模板編譯，改為固定模板與一般字串參數。

4. 漏洞詳情：Handlebars AST 型別混淆程式碼執行

識別：CVE-2026-33940 / GHSA-XHPV-HC6G-R9C6。受影響條件是應用程式將不可信輸入直接作為 Handlebars 編譯輸入，且未修補至 4.7.9。官方安全公告描述 dynamic partial/object AST 型別混淆可導致程式碼注入。本靶機使用 4.7.8，實際 RCE callback 確認可執行 shell 命令。

利用條件與影響

需要有效的 Web 應用 session 與有效 CSRF token，向 POST /character 傳送 JSON。將 campaign_message 由一般字串改為 object-shaped Handlebars AST，透過 AST 屬性型別混淆觸發執行。命令以 UID 996 的 darkzero 身分執行，工作目錄 /opt/DarkZero_Campaigns。已證明可讀取服務可讀檔及資料庫連線設定；未證明可直接取得 root。



佐證摘錄由測試端 RCE callback 保存；上圖為實測返回狀態與 uid 輸出。原始 AST payload 與含秘密的環境檔不隨公開 PDF 附送。

安全複測方式（授權實驗室）

1) ■■■■■■■■■■■■■■ dz.sid ■ _csrf■
2) POST /character■campaign_message ■■ object ■ JSON■■■■■■■
3) ■ callback ■■■■■■■■■■■■■■■■ id / hostname■■
4) ■■■■■■■■■■■■■■■■■■■■■■■■ 4xx■
5) ■■■■■■■■ callback ■■■■

不得在正式服務用讀旗標或下載 shell 作為驗證；在正式環境以 id/hostname 等無害輸出與隔離 callback 佐證。

5. 漏洞根因與修補建議

根因是輸入信任邊界錯誤：validator 對欄位只做長度檢查，Service 將 request 資料直接送進模板編譯器。Handlebars 是模板引擎，不是對使用者內容執行 compile 的沙箱。依賴版本停在 4.7.8。

優先序	修補工作	驗收方法
P0	升級 handlebars 至修補版本 4.7.9 或更新版；鎖定並重建 lockfile	SCA 確認解析版本；重跑相同 AST 型別測試，要求 4xx 且無 callback
P0	移除 Handlebars.compile(customMessage)；使用固定模板，將自訂訊息只當純文字資料	程式碼搜尋不再有使用者輸入流入 compile()
P0	在 schema 中明確限制 campaign_message 為 string；控制器與 service 層雙重檢查	物件、陣列、null、超長值皆拒絕；一般字串正常
P1	輪替 .env 中資料庫與 session secret；檢查暗示遭讀取的憑證重用	舊憑證失效；secret 不在回應、log、repo 或備份中
P1	重建隔離 runner；fork PR 預設不可取得機密與內網；明確 approval 與最小權限	惡意 PR 無法讀取 svc-runner home/keytab 或宿主機檔案
P2	啟用 Helmet 安全標頭、HTTPS 與 Secure cookie；加強稽核日誌	自動掃描確認 CSP/HSTS等標頭；session Secure 與 HttpOnly

資料庫設定檔曾可由 darkzero 讀取，PDF 已遮蔽密碼與 secret。立即輪替憑證，並檢查資料庫登入、Gitea PR/Actions、SSH、Kerberos 與 domain controller 的相關安全紀錄。

6. 取得初始服務帳號與內部身分證據

RCE 以 darkzero 身分讀取應用程式 .env，發現資料庫連線帳號與 session secret（本報告不揭露值）。資料庫 users 表中有 admin 與 josh 帳號雜湊。測試端成功驗證 josh 的網域 Kerberos 身分，並透過 SPNEGO 呼叫內部 Gitea API，識別為 darkzero-ext_josh。

可重現檢測 SOP

```
[redacted] shell [redacted]
getent passwd josh svc-runner administrator
realm list
# [redacted] TGT[redacted]
kinit josh@DARKZERO.EXT
klist
# [redacted] Kerberos [redacted] Gitea [redacted]
curl --negotiate -u : --resolve gitea.darkzero.ext:3000:172.16.20.2 \
  http://gitea.darkzero.ext:3000/api/v1/user
```

內部拓樸觀察

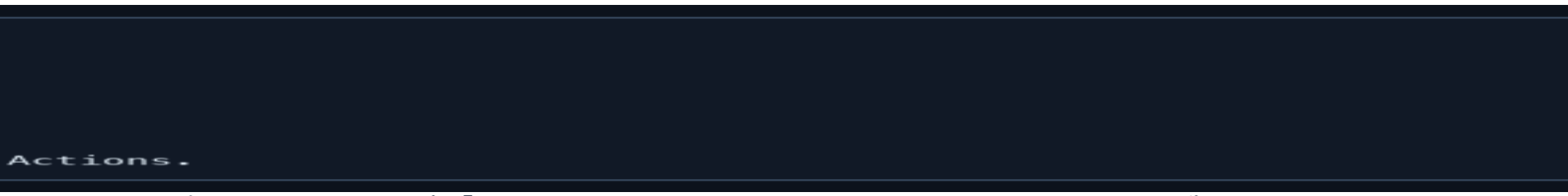
資產	已觀察
SRV01	172.16.20.3；Ubuntu 24.04.4；服務執行帳號 darkzero
DC02	172.16.20.2；LDAP 389、SMB 445、WinRM 5985、Gitea 3000 可達
網域	darkzero.ext / DARKZERO.EXT；SSSD/AD 整合
Gitea	1.25.0；內部服務，Kerberos SPNEGO 登入；私有 DarkZero/DarkZero-Campaigns repo

可讀憑證應視為已外洩並輪替。密碼、hash、session secret、cookie 與 keytab 均不應放進對外報告或 GitHub 檔案。

7. Gitea Actions 路徑與實測限制

原始 DarkZero/DarkZero-Campaigns repo 的 .gitea/workflows/main.yml 在 push 與 pull_request 時執行 npm ci、npm test、npm run build，runner label 為 ubuntu。對 fork branch 的 package.json test 命令加入讀取 /home/svc-runner/user.txt 與 callback 的驗證後，建立 fork 與 PR。這是對攻擊面影響的授權驗證；PR 未合併。

實測阻礙



上游 PR commit status 回報「Blocked by required conditions」。fork Actions API 顯示 push job 為 queued、runner label ubuntu；fork runner 清單空。SRV01 上 gitea-runner.service 雖 active，但 runner 註冊/設定檔由 svc-runner 保護，無法以 darkzero 讀取。josh 沒有 upstream 合併或上游 Actions 管理權。user.txt callback 未收到內容。

維運/藍隊檢測 SOP

```
Gitea UI/API■
- ■■ DarkZero-Campaigns ■ PR #1■commit status CI / ci (pull_request)■
- ■■ Gitea Actions run/job status■runner label ■ approval queue■
SRV01■■■■■■
systemctl status gitea-runner
journalctl -u gitea-runner --since "1 hour ago"
# runner config■keytab ■ ccache ■■■■ svc-runner/root ■■■
# ■■■■ PR/fork/branch ■ runner ■■■■■
```

風險判定：倘若未授權外部帳號能觸發該 CI，workflow 步驟與 npm scripts 皆可能以 runner 身分執行。應停用不必要的 fork PR workflow、在人工核准後使用一次性隔離 runner，且不將 host filesystem、AD 憑證或內網 secrets 暴露給不可信分支。

8. 系統權限與旗標檢測結果

以 darkzero 執行 whoami/id 確認 UID 996。檢視 sudo policy 時未取得可用規則；SUID 列表包含 ksu.mit，但在目前服務程序 no_new_privs 約束下嘗試無法 reclaim root UID。以 josh 密碼嘗試本機 SSH 與 su 亦未形成可用 session。這些結果不構成已取得本機 root。

目標	檢測結果	狀態
/home/svc-runner/user.txt	僅存在於預期 runner 使用者的權限邊界；CI 未獲批准/未執行完成，回呼無資料	未讀取
/root/root.txt	SRV01 的 /root 權限未取得；domain controller 的 Administrator flag 亦未取得	未讀取
SUID / sudo	sudo -n -l 不能取得有效授權；SUID ksu 受 no_new_privs 限制	非提權成功
旗標值	沒有讀取或驗證任何 flag；未使用外部 write-up 中的猜測值	不提供

後續人工授權排查建議

先處理 Gitea Actions fork approval 與 runner queue，再確認只讀 CI 是否由 svc-runner 執行。取得 user.txt 後再沿 AD 權限及備份存取權限評估 domain escalation；每一步需以實際 ACL、Kerberos/LDAP/SMB 回應與旗標檔案 hash/內容作證。不要把未經驗證的公開 write-up credential 當成證據。

可供藍隊查詢的檢測位置

位置 / 記錄	檢查內容
nginx access/error log	POST /character 的 object 型 campaign_message、異常 4xx/5xx、同帳號短時間多次建立角色
應用程式日誌	模板編譯錯誤、child_process 執行、異常命令與 callback 外連；補上 request id/使用者 id
MySQL audit/general log	異常讀取 users 表、來自應用帳號的大量查詢、來源與時間
Gitea audit/Actions	fork、分支、PR、approval、workflow push/PR runs、package.json 改動及 job 執行記錄
SRV01 auth / SSSD / Kerberos	kinit、SSH/PAM 登入失敗或成功、跨帳戶切換、keytab 使用及 svc-runner activity

9. 偵測規則與事件回應

建議 SIEM 對下列行為做關聯，而不是單看單一請求：同一 session 呼叫 POST /character、campaign_message JSON 型別非 string、接續 Node.js 子程序或對外 HTTP/DNS callback；同一帳號建立角色後又讀取 .env 或透過 Kerberos 存取 Gitea；fork PR 在 package.json/npm scripts 出現 shell、curl、base64 或讀取 /home 檔案。

簡化偵測邏輯（WAF/應用層）

```
IF method=POST AND path=/character
 AND JSON_TYPE(campaign_message) != STRING
THEN alert high; reject request; preserve sanitized body metadata

IF process.parent in (node, npm) AND process.name in (sh,bash,curl,wget,python)
THEN alert critical; capture process tree + user + cwd + remote endpoint

IF repository fork PR changes package.json scripts or .gitea/workflows/**
THEN require manual review before any runner executes it
```

應保存的檢測檔案 / 文件

記錄	最小保存欄位	保留注意事項
Web access/error	時間、request id、來源、路徑、HTTP狀態、session 使用者代號	cookie/CSRF/密碼不落日誌
App process audit	execve、parent pid、uid、cwd、binary hash、network destination	可用 auditd/EDR 或容器 runtime
Gitea audit	actor、repo、fork、branch、PR、diff、workflow run/job、approval actor	保存 workflow YAML 與 commit SHA
系統認證紀錄	sshd、PAM、SSSD、Kerberos TGT/service ticket、systemd runner	keytab/ccache 僅記錄 metadata，不複製秘密
資料庫稽核	登入帳號、來源、SQL operation、資料列數、時間	避免保存原始密碼/hash

事件處理順序：隔離 Web 服務 → 保存 memory/process/network 與日誌 → 停止不可信 Actions runner → 輪替 session/DB/AD 憑證 → 修補依賴與輸入驗證 → 重建乾淨主機 → 驗證旗標/敏感資料未被外傳。

10. 證據、檢測檔案與可重現清單

主要證據位於測試工作區 reports/10.129.156.169/。原始 exfil 目錄含敏感資料與個人化 session 輸出，不應上傳 GitHub；公開 PDF 僅引用已遮蔽的必要證據。

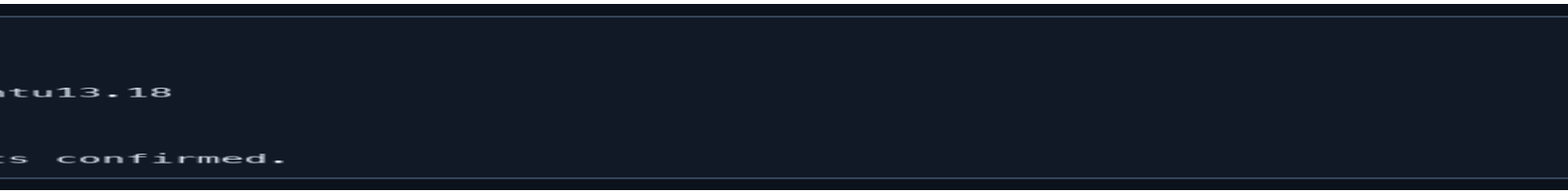
檔案	用途 / 佐證
reports/10.129.156.169_tcp_services.nmap	nmap 22/80 服務指紋與掃描時間；全埠掃描另有 timeout 紀錄
reports/10.129.156.169/web/	登入、頁面、headers、角色建立與 campaign response 的 HTTP 擷取
reports/10.129.156.169/exfil/MessageService	MessageService 將 customMessage 送入 Handlebars.compile 的原始程式碼片段
reports/10.129.156.169/exfil/Pkg	package metadata，確認 handlebars 版本 4.7.8
reports/10.129.156.169/exfil/INTERNALPORTS	SRV01 至 DC02 LDAP/SMB/WinRM/Gitea 連線可達性
reports/10.129.156.169/exfil/STATUS	上游 PR commit status blocked by required conditions
reports/10.129.156.169/exfil/FORKRUNS、RUNJOBS、RUNNERS	fork workflow queued、ubuntu label、fork runners 清單空
reports/10.129.156.169/exfil/RUNNERMETA、RUNNERLOGS	gitea-runner 服務為 svc-runner 身分運作；一般服務帳號無權讀日誌/設定

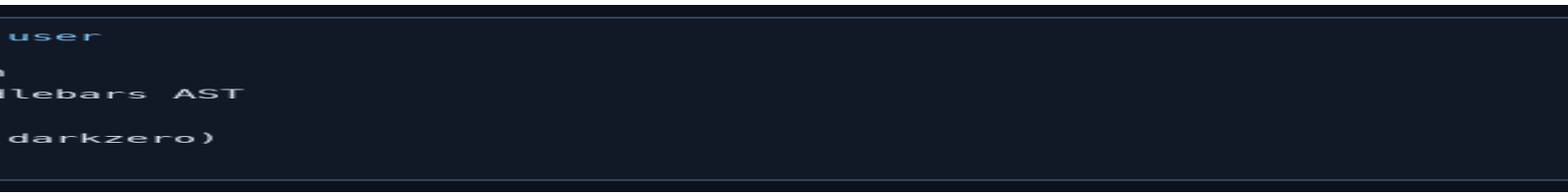
紅隊可重現檢查點

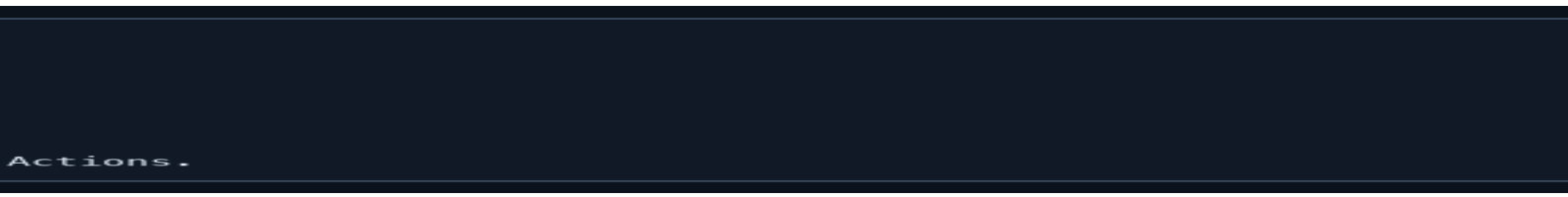
```
A. nmap ■■ 22/80■■■■■■■■ timeout■
B. ■■■■■■ /character API request/response■
C. ■■ CharValidator■MessageService■package-lock■■■■■■■
D. ■■■■■ AST object ■■■■■■■ callback ■■ id=darkzero■
E. ■ Kerberos SPNEGO ■■ Gitea /api/v1/user■■■ josh■
F. ■■ upstream PR status ■ fork Actions run/job■■■■■■■■■
G. ■■ user.txt/root.txt ■■■■■■■■■■■■■■■■■■■■■■
```

附錄 A. 測試證據圖片

以下為測試端保存的命令輸出截圖式摘錄，保留了關鍵服務、執行身分與 Gitea workflow 狀態。原始檔名與時間可在證據清單中對照。







附錄 B. 風險評級與限制

Critical：未登入或一般低權限使用者能透過應用漏洞在服務端執行任意命令，且本次已實際驗證；其後端資料庫秘密可讀。High：憑證及 secrets 暴露會擴大到內網服務。Medium：CI runner 以服務帳號執行 repository 程式碼，若 approval 或 runner 隔離失效會造成橫向影響。

限制與未完成事項

1. 全 TCP 掃描未完成，請安排較長窗口重測。
2. 未取得 user.txt、root.txt；本次不宣稱完成完整旗標鏈。
3. 上游 PR run 因 required conditions 阻擋；fork push run 仍 queued，未實際執行 npm test。
4. 未取得 root、svc-runner 或 DC 管理權限。
5. 報告中的內部網段和網域資訊只在靶機連線與設定檢查中觀察，未擴大掃描範圍。

來源與參考

1. Handlebars 官方安全公告 GHSA-XHPV-HC6G-R9C6 / CVE-2026-33940：https://github.com/handlebars-lang/handlebars.js/security/advisories/GHSA-xhpv-hc6g-r9c6
2. Gitea 官方文件：fork pull request workflow 可能需要人工 approval；Actions run approval API：https://docs.gitea.com/api/operations/approve-workflow-run/
3. 測試對象：Hack The Box DarkZeroReturns，10.129.156.169。

報告狀態：授權測試部分完成。旗標、root 與網域提權鏈需要在 CI approval/runner 條件可用後接續驗證。